

Final Release-Gate QA Report

University Easy Plans · JO0Dile/MyMenuPack · commit 6c747c8

Third pass. Brief: find what the previous two passes could not reach. 16 August 2026

NEW BUGS FOUND	FIXED	CRITICAL LEFT	HIGH LEFT	VERDICT
1 low severity, hardening	1 re-verified	0 none	0 none	READY* *with stated caveats

Executive summary

This pass deliberately avoided repeating the previous suite. It targeted the gaps: simulated server failure, storage exhaustion, schema migration, leaks at scale, the service-worker update path, the real first-run experience, the actual GitHub Pages subdirectory deployment, and business-logic abuse. **It found one new defect, of low severity.** Everything else held.

The honest headline is that the application did not break under this pass. That is a result, not an absence of testing — but it is bounded by what this sandbox can reach. **Three areas remain genuinely unverified and one of them is security-relevant** (server-side authorization). Those are listed explicitly rather than presented as passes.

The one new bug

1	window.open() did not pass noopener LOW · web/js/28-imported.js (2 call sites)
Found by	Source-level review of every primitive in the Phase 0 inventory.
Issue	Both <code>window.open(url, '_blank')</code> calls gave the opened page a live <code>window.opener</code> handle back into the app (reverse tabnabbing).
Severity	LOW, and deliberately not inflated. The URLs are developer-configured constants — not user input, not feed-controlled — so this is hardening, not a reachable exploit. It is reported because the app's <i>own</i> Fix analyzer already flags this exact pattern for <code></code> , so the same standard should apply to script-opened tabs.
Fix	Pass 'noopener' at both call sites.
Regression	CI at baseline; sweep, consistency, prerequisite, offline and interaction suites all clean.

New ground covered, and what it showed

Area (never tested before)	Volume	Result
Simulated server failure	37 injected responses	Every HTTP status 400-504, empty / whitespace / HTML / malformed / truncated / wrong-schema JSON, prototype-pollution and XSS payloads in the feed, connection reset, DNS failure, and a 30s hang. No finding. The app falls back to its cached catalogue, never loses stored plans or progress, never executes, never pollutes.
Storage exhaustion	setItem throws, getItem throws	No finding. App stays alive (15,587 chars, 51 courses); GPA still computes when reads are blocked, which is the private-mode shape.

Area (never tested before)	Volume	Result
Schema migration	8 legacy/future shapes × 2 loads	No finding. All render 25–26 cards, and every migration is idempotent — the second load produces byte-identical storage.
Leaks at scale	3,200 operations	1,000 modal cycles, 1,000 searches, 500 theme changes, 500 language toggles, 200 plan switches. DOM +250 nodes, heap –1 MB, overlays +0. No leak.
Service-worker update	cache deleted mid-session	No finding. The open tab kept all 51 courses, reload recovered, and the completed course survived.
GitHub Pages subdirectory	served at /mymenupack/	No finding. Correct SW scope, cache created, offline reload works, zero failed requests. This is the real deployment shape and had never been exercised.
Real first-run	wizard, both paths	No finding. Skip and full completion both work; a brand-new user reaches a plan with 50 courses. 5 of 13 majors are pending and show an honest toast rather than failing silently.
Business-logic abuse	forged state	Fabricated completions produced zero credit; grading a locked, incomplete course added zero credit; 500 fabricated course ids gave no NaN, no >100%, no phantom courses.
Invariant-checked chaos	180 ops, 180 checks	3 sessions × 60 mixed operations including reloads, offline toggles, edit mode and grade changes. Zero invariant violations.
Accessibility modes	forced-colors, reduced-motion, 200/300/400% zoom	No finding. 51 courses render in every mode, 0 invisible controls, and no horizontal scrolling at 400% — WCAG 1.4.10 reflow passes.
Real mobile	touch, double-tap, rotation, keyboard	No finding. Accidental double-tap nets no change; modal survives rotation; no overflow in either orientation or with the keyboard up.

Rejected — harness artifacts, not defects

Six findings were investigated and discarded. They are listed because a report that hides its own false starts cannot be trusted about its real ones.

- **15 false CRITICALs** — the local test server died mid-run, so pages could not load. Every "execution context destroyed" traced to that, not the app. A server-health guard was added to the harness and the suite re-run clean.
- **"A brand-new user cannot reach a study plan"** — investigated four separate ways before rejecting. Causes were all mine: a .uni-card selector for a class that does not exist; the home screen keeping every drill-down level in the DOM and toggling visibility, so hidden tiles were being queried; a loop that re-clicked the same first tile; and an "openable" regex that missed selectAndOpen. The real flow works.
- **"Onboarding wizard has no buttons / will not close"** — the wizard ends with the overlay at display:none and zero size; the card element simply remains in the DOM as reusable markup. Tiles underneath are fully clickable.

UNVERIFIED — not claimed as passing

Area	Why it could not be tested
Firefox, WebKit, Safari, Edge	Playwright resolves the binaries but they are not installed , and the download host is blocked by the sandbox proxy (HTTP 403). No system browser exists either. Every result in this report is Chromium-only.
Server-side authorization	The most important gap. The admin Worker is unreachable from this sandbox. Only client-side bypass was tested (setting fake admin flags in localStorage did not unlock the dashboard). Horizontal and vertical authorization, token handling, and privileged endpoints are UNVERIFIED .
Cloud Sync and the AI Worker	Both Workers unreachable (ERR_TUNNEL_CONNECTION_FAILED). The assistant was exercised in offline grounded mode only.
Screen readers	NVDA, VoiceOver and TalkBack are not available here. Labels, roles, focus order and keyboard operation were checked; actual assistive-technology output was not.
Real devices and printers	Emulated viewports and touch only; print-media emulation only.

Release recommendation

READY for the public release you are planning — a student-facing, offline-first planner served from GitHub Pages — subject to two conditions being understood rather than assumed:

- **Browser coverage is Chromium-only.** Nothing here says the app is broken elsewhere; it says nobody has checked. Before or shortly after launch, open it once in Firefox and once on a real iPhone. The two engine-specific risks worth a glance are the *storage* event (the multi-tab fix depends on it) and Escape-key handling on modals.
- **Server-side authorization is unverified.** If the admin Worker is reachable by anyone but you, it needs its own authorization test before you rely on it. Nothing in this pass proves it is safe — or unsafe.

Against the release gate itself: 0 critical, 0 high, no known data-loss bug, no known XSS, no known client-side authorization bypass, no known state-corruption bug, no known mobile blocker, and no accessibility release-blocker. The gate's remaining clauses — all reachable APIs and Workers tested, server-side authorization verified — are satisfied only for the surface that is actually reachable from here, which is why the verdict carries an asterisk rather than being stated flat.

Cumulative across three passes: ~1,100 + ~1,600 assertions, 9 bugs found, 9 fixed. Fixes on `claude/claude-capabilities-environments-k88hlo`; this pass is commit `6c747c8`. Service worker at `v43`.